STRIDE IISP 7.0

Vulnerability Management Policy

Version [1.0]

Purpose

This Vulnerability Management Policy is designed to serve as a comprehensive resource for multiple stakeholders. It guides internal teams responsible for executing vulnerability management processes, informs external partners about Stride's security expectations, and provides transparency for regulators and auditors evaluating our cybersecurity posture.

The policy reflects Stride's commitment to open, responsible, and collaborative information security practices. By clearly defining our approach to vulnerability identification, assessment, and remediation, we aim to foster trust, support compliance efforts, and ensure a shared understanding of our risk management strategies. This document reinforces Stride's belief that strong security governance is not just a technical imperative, but a core element of our organizational responsibility.

Scope and Applicability

These policies and standards apply to all Stride-owned technology and business operations.

All workforce members and their respective facilities supporting Stride business operations, technology, or both, wherever Stride data is stored or processed, including any third party contracted by Stride to handle, process, transmit, store, or dispose of Stride data are subject to the requirements of this document.

All data, systems, activities, and assets owned, leased, controlled, or used by Stride, its agents, contractors, or other business partners on behalf of Stride are within the scope of the requirements of this document.

The requirements outlined in this document apply where technically feasible and commercially reasonable, as determined by executive management. Any exceptions to these standards must be requested using the approved workflow and remain documented until compliance has been achieved. Exceptions are only granted temporarily for periods of up to one calendar year.

Definitions

All definitions are located within Stride - ISP 1.2 – IT Policy Definitions.

Any inquiries regarding terminology or clarity may be directed to Stride's Information Security Team for assistance.

Publication Owners

Johnny Burns – Point of Contact, Content Coordinator & Author

Jen Havenner – Business Owner

Mark Williams – Executive Sponsor

Document Control

This document may contain proprietary, confidential, or sensitive information owned wholly by Stride Inc. Any distribution of the information contained within this document, in whole or in part, outside of Stride or its subsidiary entities requires the approval of the Chief Information Security Officer (CISO).

This document will be reviewed at least annually and re-issued when revisions are necessary. Any changes introduced in the most recent version are itemized below. Obsolete copies should be destroyed or archived upon the release of the newest version.

Implementation and Compliance

All business units are required to comply with any changes applied to the most recent version of this publication within 90 days from the date of publication.

Change History

Version	Date of Change	Summary of Change(s)
1.0	03/24/2025	Initial Draft
1.0	09/10/2025	Approved by Hassan Raja & Jen Havenner
1.0	09/10/2025	Approved by CISO/VP Information Security
1.0	09/11/2025	Published

Vulnerability Management Program Overview

Stride's Vulnerability Management (VM) policy provides a structured and proactive process to manage the full lifecycle of vulnerabilities across its digital infrastructure. This includes identifying, classifying, remediating, and mitigating vulnerabilities in systems, applications, and networks.

Using a combination of enterprise vulnerability management platforms and industry best practices, Stride's cybersecurity team performs routine assessments to identify weaknesses in:

- Network Infrastructure
- Operating systems and endpoints
- Cloud applications
- Databases and data repositories
- Third-party integrations and external interfaces

Once vulnerabilities are discovered, they are evaluated and prioritized using a risk-based approach. Priority is determined by assessing:

- The severity and exploitability of the vulnerability
- The criticality of the affected asset
- The likelihood of exploitation
- The potential business impact if exploited

Remediation strategies may include patching, configuration changes, software updates, compensating controls, or, in rare cases, replacing vulnerable systems. Remediation efforts are implemented with minimal business disruption and in alignment with operational change management processes. The overarching goal is to reduce risk exposure and strengthen the confidentiality, integrity, and availability of Stride's information systems.

Guiding Principles

Stride's VM program is driven by a set of core principles that support its commitment to secure and reliable operations:

- **Continuous monitoring:** Environments are continually scanned to detect vulnerabilities early and respond before exploitation occurs.
- **Risk-based prioritization:** Resources are focused on vulnerabilities that pose the greatest threat, determined by a combination of CVSS severity, exploitability in the wild, asset criticality, and potential business impact.
- **Rapid response:** Swift and organized remediation processes reduce exposure to windows and limit potential damage. Zero-day and actively exploited vulnerabilities are remediated on an accelerated timeline (24-48 hours depending on exposure.

- **Secure by design:** Secure coding practices, system hardening, and architecture reviews are built into the software development life cycle (SDLC) Application-layer vulnerabilities identified through testing (SAST, SCA, DAST, API security) are addressed under the same risk-based approach.
- **Defense-in-depth:** Security is layered to ensure that the failure of one control does not expose the entire system.
- **Shared responsibility:** Security is a collective responsibility that spans across IT, security, development, operations, and business units.

Roles and Responsibilities

A successful VM program depends on clear ownership and collaboration between internal and external stakeholders.

Team Roles

- **Chief Information Security Officer (CISO):** Provides strategic leadership for the Vulnerability Management program, ensuring alignment with organizational goals and promoting a culture of proactive security and risk awareness.
- **Vulnerability Management:** Manages the day-to-day operations of the VM program, including scheduling and executing vulnerability scans, coordinating with IT Operations and Infrastructure teams, and collaborating with IT Risk Management to document, track, and prioritize identified risks.
- **IT Risk Management:** Conducts risk analysis on identified vulnerabilities, supports remediation planning, and ensures risks are appropriately categorized and addressed in accordance with organizational risk tolerance.
- **IT Operations and Infrastructure Teams:** Executes remediation activities based on vulnerability findings, maintains and updates scanning tools, and works closely with development teams and business units to ensure timely and effective resolution of security issues.

External Stakeholders

- **Third-party service providers:** Required to adhere to Stride's VM policies by conducting regular vulnerability scans on their systems, applying timely security patches, and reporting any vulnerabilities that may pose a risk to Stride's environment. Their compliance is critical to maintaining a secure supply chain.
- **Regulatory bodies:** Serve as oversight authorities by conducting audits, issuing compliance guidelines, and enforcing legal and industry standards. Their input ensures Stride's VM program remains aligned with evolving regulatory expectations.
- **Audit partners:** Perform independent assessments of Stride's VM program to evaluate its effectiveness, identify gaps, and provide actionable recommendations. Their reviews help validate compliance and drive continuous improvement.

- **Clients and customers:** While not directly involved in vulnerability management, they contribute to the overall security posture by practicing safe digital behaviors, reporting suspicious activity, and maintaining vigilance in their interactions with Stride's systems and services.

Core Vulnerability Management Processes

Stride's Vulnerability Management (VM) process is a dynamic and end-to-end framework, structured around five core stages that ensure continuous improvement, risk reduction, and operational resilience.

Vulnerability Identification

Stride performs routine vulnerability scans across all in-scope assets to proactively identify and mitigate security risks. This includes:

- **Cloud-hosted environments** (e.g., IaaS, PaaS, SaaS platforms)
- **Newly deployed production assets**, including applications, services, and infrastructure components

All assets with scanning capability are included in the scope. Vulnerability scans are conducted **at least quarterly**, with **increased frequency** for:

- Systems classified as **high-risk** based on data sensitivity, exposure, or criticality.
- Assets undergoing **significant changes**, such as configuration updates, software deployments, or architectural shifts.

Asset coverage

All assets must be included in the vulnerability program and onboarded into scanning before production release. Security Operations reconciles scan coverage against the asset inventory at least quarterly to confirm no assets are missed.

This scanning cadence provides Stride with sustained visibility into its evolving threat landscape, enabling proactive risk identification and timely remediation in alignment with recognized industry standards and security best practices.

Assessment and Prioritization

After identification, vulnerabilities are assessed and prioritized using a risk-based approach. Stride applies the **Common Vulnerability Scoring System (CVSS)** as a baseline, enhanced by additional risk factors such as exploit availability, active threat intelligence, asset criticality, and business impact.

Severity Categories:

- **Critical (CVSS 9.0–10):**
  - Vulnerabilities that significantly impact operational integrity or security. Immediate remediation is required to prevent disruption or breach.
- **High (CVSS 7.0–8.9):**
  - Vulnerabilities that pose a serious potential threat. These must be prioritized for remediation to reduce exposure.
- **Moderate (CVSS 4.0–6.9):**
  - Issues that could impact performance, maintainability, or internal security. They should be remediated in a timely manner but are not an immediate threat.
- **Low (CVSS 0.1–3.9):**
  - Minor issues with limited current impact. Documented and scheduled for remediation as part of ongoing maintenance.
- **Informational (CVSS 0.0):**
  - Findings that do not represent vulnerabilities but highlight practices that could be optimized.

Additional Prioritization Factors:

- Sensitivity of the affected asset or data
- Business function of the system.
- Number of systems affected.
- Alignment with Stride's risk tolerance.
- Exploit activity in the wild (e.g., CISA KEV, vendor advisories).

Application Security Integration:

Vulnerabilities identified in Stride applications (e.g., via SAST, SCA, DAST, or API testing) are categorized and remediated using the same severity levels and timelines as infrastructure vulnerabilities.

Remediation and Implementation

Remediation actions may include:

- Applying vendor-released patches.
- Reconfiguring insecure system settings.
- Updating or upgrading software versions.
- Disabling unused services or protocols.
- Deploying compensating controls when immediate remediation is not possible.

Requirements for Go Live:

Critical and High vulnerabilities must be remediated before production release.

Moderate and Low vulnerabilities may be scheduled post-launch with documented remediation plans.

Policy Exceptions:

When remediation cannot be completed within the defined Service Level Agreement (SLA), a formal policy exception must be requested. The following guidelines apply to all policy exceptions:

- **Submission**: Exceptions must be submitted through the Governance, Risk, and Compliance (GRC) team.
- **Approval:** Each request follows a structured approval workflow to ensure appropriate oversight.
- **Duration:** Exceptions are granted for a maximum of 12 months and are subject to quarterly reviews.
- **Compensating Controls:** Adequate compensating controls must be implemented to mitigate associated risks.
- **Testing Requirements:** All remediation activities must be validated in a controlled environment to prevent the introduction of instability or new risks.

Verification

After remediation, SecOps performs follow-up scans or manual validation to confirm:

- The vulnerability has been fully mitigated.
- No new vulnerabilities were introduced as part of remediation.
- The risk level of the affected system has been reduced appropriately.

Exploited Vulnerabilities:

If a vulnerability is confirmed to be actively exploited in the wild, it must be escalated to Incident Response. Exploited Critical vulnerabilities require remediation or mitigation within 24 hours.

Reporting and Communication

Stride maintains consistent communication with stakeholders through:

- **Internal reporting**: Regular reports prepared by **Security Operations (VM Team)** for IT Operations and Risk Management, detailing vulnerability posture, SLA compliance, and remediation progress.
- **Executive dashboards**: Monthly dashboards from SecOps to leadership summarizing trends, key metrics (SLA compliance, MTTR, coverage, exceptions), and overall remediation status.

- **Audit and compliance support**: ITRM is accountable for providing documentation to auditors and regulators; SecOps supplies validated vulnerability management data and remediation evidence.
- **External disclosures**: Legal is accountable for issuing all external communications; SecOps (IR/VM) provides technical validation and impact analysis; ITRM supports as needed for regulatory assessments.
- Executive dashboards highlighting trends, metrics, and remediation status

Vulnerability Scanning Standards

Stride maintains a formalized Vulnerability Management Plan that is reviewed:

- At least annually, and
- After major organizational or infrastructure changes.

Scanning requirements:

- All in-scope enterprise assets must be scanned for vulnerabilities.
- Scope of assets is reviewed and confirmed by management on a regular basis.
- Vulnerability scans are conducted at least quarterly, with increased frequency for:
    - Internet-facing or high-risk systems,
    - Systems classified as critical based on data sensitivity, and
    - Assets undergoing significant configuration changes or new deployments.
- Newly deployed assets must be added to the scan scope prior to production release.
- SecOps reconciles the vulnerability scan inventory against the enterprise asset inventory at least quarterly to confirm full coverage.

Patch Management Integration

Patch management is a core part of Stride's Vulnerability Management program and ensures vulnerabilities identified through scanning are addressed in a timely and risk-based manner.

Patch Management Requirements:

- Relevant patches must be identified, prioritized, and scheduled according to severity and business impact.
- All patches are tested in a controlled environment before deployment to confirm mitigation effectiveness and operational stability.
- Validated patches are deployed in alignment with Stride's Patching Standard and Change Management requirements.
- Where vulnerabilities cannot be remediated within SLA, a formal policy exception must be attained.

Zero-Day and Exploited Vulnerabilities

Vulnerabilities actively exploited in the wild or identified as zero-day threats are treated as Critical and must be patched or mitigated on an accelerated timeline (24-48 hours depending on exposure).

STRIDE PATCHING STANDARD			
The table below outlines the requirements and timelines for patching vulnerabilities within Stride's IT environment. It ensures that vulnerabilities are addressed in a manner that mitigates risks to the organization, particularly for systems handling sensitive data.			
Severity Tier	**Criticality**	**Definition**	**Schedule (SLAs)**
Tier 1: CRITICAL	CVSS Base Score 9.0-10.0	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is exposed to the Internet.	Vulnerabilities must be patched within 48 hours of identification to minimize exposure and prevent potential exploitation. Rapid response is essential to maintaining the integrity and security of Stride's most sensitive assets.
Tier 2: CRITICAL	CVSS Base Score 9.0-10.0	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is NOT exposed to the Internet.	Vulnerabilities must be patched within 5 business days of identification to prevent potential exploitation and ensure rapid risk mitigation.
Tier 3: HIGH	CVSS Base Score 7.0-8.9	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is exposed to the Internet.	Vulnerabilities must be patched within 10 business days of identification to minimize exposure and reduce the risk of compromise in high-threat environments.

Tier 4: HIGH	CVSS Base Score 7.0-8.9	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is NOT exposed to the Internet.	Vulnerabilities must be patched within 10 business days of identification to minimize potential impact and uphold Stride's internal security standards.
Tier 5: MEDIUM	CVSS Base Score 4.0-6.9	The system hosts or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is exposed to the Internet.	Identified vulnerabilities must be patched within 30 business days from the date of discovery to mitigate risk and maintain compliance.
Tier 6: MEDIUM	CVSS Base Score 4.0-6.9	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data. The system is NOT exposed to the Internet.	Vulnerabilities must be patched within 60 business days from the date of identification to ensure timely risk mitigation while balancing operational priorities.
Tier 7: LOW	CVSS Base Score <4.0	The system authenticates, hosts, or processes Stride Confidential, Restricted, and/or Highly Protected data.	Patching is recommended to maintain optimal security hygiene and reduce long-term risk but not mandated unless the vulnerability escalates in severity or is reclassified due to emerging threats.

References:

- Stride may utilize the following guides produced by NIST to develop, document, and perform organizational Vulnerability and Patch Management
    - **NIST Special Publication 800-37 (Risk Management Framework)**: This publication provides guidelines for managing security and privacy risks,

including vulnerability management as part of the overall risk management process

- **NIST Special Publication 800-40 (Guide to Enterprise Patch Management Planning)**: This document offers guidance on creating a patch management program, which includes vulnerability management as a key component

- Additional information can be found in NIST CSF 2.0